MÒDUL 06 · SEGURETAT INFORMÀTICA — RA5 · NF4-AA1

Protecció de dades personals



RGPD i LOPD-GDD: el dret a la privacitat a l'era digital

CFGM Sistemes Microinformàtics i Xarxes · 2n curs

Institut Puig Castellar
Joan Sánchez

EN AQUESTA SESSIÓ

Què aprendrem avui?



RGPD i LOPD-GDD

Quina és la normativa que regula la protecció de dades personals, per què existeix i a qui obliga.



Drets de les persones

Quins drets té qualsevol persona sobre les seves pròpies dades i com pot exercir-los.



Obligacions tècniques

Què ha de fer, tècnicament, una empresa o un tècnic informàtic per complir la llei.

HO SABIES?

Un dret fonamental reconegut a la Constitució

Article 18.4 CE

"La llei limitarà l'ús de la informàtica per garantir l'honor i la intimitat personal i familiar dels ciutadans i el ple exercici dels seus drets." La primera llei espanyola (LOPD) és de 1999.

Un cas històric d'advertència

Abans de 1940, el cens d'Holanda incloïa la tendència religiosa amb finalitats lícites. Els nazis el van fer servir per exterminar el 90% dels jueus holandesos. Per això les dades "especials" es protegeixen amb més rigor.

LA NORMATIVA

RGPD i LOPD-GDD: dues normes, un mateix objectiu



RGPD (2016/2018)

Reglament General de Protecció de Dades, desenvolupat per la Unió Europea. S'aplica directament a tots els estats membres. Vigent des del maig de 2018.



LOPD-GDD (2018)

Llei Orgànica de Protecció de Dades i de Garantia de Drets Digitals: la transposició espanyola del RGPD, que substitueix la LOPD de 1999.



Objectius: control de la ciutadania sobre les seves dades, regulació uniforme a Europa, lliure circulació de dades i seguretat jurídica per a l'economia digital.

ÀMBIT

A qui i on s'aplica?



S'aplica quan...

Es tracten dades de persones físiques (sense excepció de nacionalitat) de forma automatitzada o manual, en un fitxer estructurat. Obliga totes les empreses i organismes que gestionen dades personals.



Àmbit territorial

Als responsables establerts a la UE, i també als NO establerts a la UE si ofereixen béns o serveis a persones que hi resideixen. NO s'aplica a persones jurídiques ni a l'ús estrictament personal/domèstic.

CONCEPTES CLAU

Dada personal i categories especials

- Dada personal: qualsevol informació sobre una persona física identificada o identificable (l'interessat) — un nom, un DNI, una IP, dades de localització…
- Tractament: qualsevol operació sobre dades personals: recollida, registre, conservació, modificació, consulta, comunicació, supressió…



Categories ESPECIALS (protecció reforçada): origen ètnic/racial, opinions polítiques, conviccions religioses, afiliació sindical, dades genètiques/biomètriques, salut, vida sexual.

EL CONSENTIMENT

Quan i com cal demanar-lo

- Ha de ser una declaració inequívoca o acció afirmativa clara: NO valen caselles premarcades ni el silenci/inacció.
- Explícit (marcar un "SÍ") en: dades especials, decisions automatitzades i transferències internacionals.



Menors d'edat

El RGPD fixa 16 anys com a edat mínima per consentir, però permet als estats rebaixar-la fins a 13. A Espanya, la LOPD-GDD la fixa en 14 anys.



Sense consentiment

No cal si hi ha interès legítim (seguretat, prevenció de frau), dades de contacte professional, videovigilància, o oposició a rebre publicitat.

DRETS DE LES PERSONES

De l'ARCO als nous drets digitals

- Informació: saber com, per què i durant quant de temps es tracten les teves dades.
- Accés: confirmar si es tracten les teves dades i obtenir-ne una còpia.
- Rectificació: corregir dades inexactes.
- Supressió i dret a l'oblit: eliminar les dades (i que s'informi altres responsables si són públiques).
- Oposició: oposar-te al tractament (amb excepcions d'interès públic o legítim).
- Portabilitat: rebre les teves dades en format estructurat i transmetre-les a un altre responsable.
- Limitació del tractament: "congelar" el tractament mentre es resol una reclamació.
- No ser objecte de decisions automatitzades: exigir intervenció humana en decisions que t'afectin significativament.

CAS REAL

Google sancionat per cessió de dades a tercers

L'Agència Espanyola de Protecció de Dades (AEPD) ha sancionat diverses vegades grans tecnològiques per infraccions del RGPD, com Google per cedir dades a tercers sense base legal adequada, o Vodafone (170.000€) per no aplicar mesures per evitar la suplantació d'identitat.

Les sancions poden arribar fins a 20 milions d'euros o el 4% de la facturació anual global de l'empresa (la xifra més alta de les dues), en les infraccions més greus.

FIGURES RELLEVANTS

Qui és qui en el tractament de dades

Figura	Funció
Interessat	La persona física de la qual es tracten les dades.
Responsable del tractament	Qui determina les finalitats i mitjans del tractament (ex: una empresa de telecomunicacions).
Encarregat del tractament	Qui tracta dades per compte del responsable (ex: una empresa subcontractada).
Delegat de Protecció de Dades (DPD)	Supervisa el compliment del RGPD; obligatori en organismes públics o tractaments a gran escala.

INCIDENTS

Violacions de seguretat: què cal fer



Una violació de seguretat és qualsevol incident (destrucció, pèrdua, alteració o accés no autoritzat) sobre dades personals. Cal notificar-la a l'AEPD en un termini màxim de 72 hores des que se'n té constància.

- Cal documentar TOTES les violacions, encara que no calgui notificar-les.
- Si hi ha alt risc pels drets dels interessats, també cal notificar-los directament a ells.
- No notificar és una infracció greu: fins a 10 milions d'euros o el 2% de la facturació anual.

COMPLIMENT

Mesures de responsabilitat activa ("accountability")



Registre i anàlisi de risc

Registre d'activitats de tractament (empreses >250 treballadors) i anàlisi dels riscos de cada tractament.



Mesures tècniques

Bloqueig, contrasenyes robustes, xifratge, destrucció segura, control d'accés per usuari (principi del mínim privilegi).



Disseny i notificació

Protecció des del disseny (privacy by design), i notificació de violacions en 72h.

FORA DE LA UE

Transferències internacionals de dades

- Només es poden transferir dades fora de la UE si el país destí ofereix un nivell de protecció adequat (llista oficial de l'AEPD: EEE, Suïssa, Andorra, Regne Unit, Canadà...).
- O bé si hi ha garanties contractuals adequades, o s'aplica alguna excepció legal.
- Cas especial: els EUA. L'acord "Privacy Shield" va ser invalidat pel Tribunal de Justícia de la UE el 2020; actualment hi ha un nou marc (Data Privacy Framework / "Privacy Shield 3.0").

PER ACABAR

Idees clau d'avui



RGPD + LOPD-GDD

Marc legal europeu i espanyol que protegeix el dret fonamental a la privacitat de les dades personals.



Drets ampliats

De l'ARCO clàssic als nous drets digitals: portabilitat, oblit, limitació, no-decisions automatitzades.



Responsabilitat activa

No n'hi ha prou en complir la llei: cal poder DEMOSTRAR-HO (accountability), amb mesures tècniques i organitzatives.

ARA ÉS EL TORN VOSTRE



Una clínica dental digitalitza els historials clínics dels pacients i els emmagatzema al núvol.

En parelles: identifiqueu 1) si necessita un DPD i per què; 2) tres mesures tècniques de responsabilitat activa que hauria d'aplicar; 3) què hauria de fer si, per un error de configuració, els historials queden accessibles sense contrasenya durant 3 dies.

15 minuts en parelles + posada en comú

FONTS DEL MATERIAL

Webgrafia

NF4-AA1: Protecció de dades (LOPD-GDD i RGPD)

Repositori "Materials" (GitHub, SMX-0226SI) · basat en material de Pau Tomé (IES Bosc de la Coma) · Llicència CC-BY-SA-4.0 — github.com/SMX-0226SI/Materials/blob/main/NF4/01.LOPD-RGPD/lopd.md

Agència Espanyola de Protecció de Dades (AEPD)

aepd.es — guies, sancions i registre d'autoritats de protecció de dades.

INCIBE — RGPD para pymes

incibe.es/protege-tu-empresa/rgpd-para-pymes

Llicència CC BY-SA 4.0 · Adaptat de "Materials" (SMX-0226SI), Carlos Alonso Martínez, Escola Pia de Mataró